ISEP

Segurança de Sistemas e Informação (SEGSI)
PL04
Joaquim Filipe Peixoto dos Santos (**JPE**)
Pedro Filipe Cruz Pinto (**PFP**)
Dílio Adalberto da Rocha Ribeiro (**DAR**)
Daniela Alexandra Pires Pinto (**DPI**)
{ @isep.ipp.pt }

Exercise 1: DACLs

To do this exercise, set up the following:

1. Download a Trial image from Microsoft Download Center of Windows 2019[1].
2. Install it on a Virtual Machine.
3. Update the installation with all patches.
4. Promote your server to Domain Controller.

Microsoft Active Directory uses a specific model to grant permissions to objects. It is possible to state, to a certain extent, what actions can be done to certain objects by a set of users. In this exercise, we want to create a pseudo environment where the student can understand what kind of Special permissions can be created in such an environment.

5. Create example groups such as Finance, Service Desk, HR, SysAdmin.
6. Grant permissions such that service desk personnel is able to reset Finance User's Account Passwords.
7. Grant Permissions for the SysAdmin personnel to add people to the Domain Administrator's Group.
8. Grant permissions to the HR department to Write the Personal Information of each employee.
9. SysAdmin Accounts are able to change group memberships.
10. What limitations do you foresee in considering this approach at scale?
11. Since you are giving permissions to users, what additional security controls should you apply to secure (or at least track) malicious actors?
12. Imagine that you want the exclude one person from a group's permission, how do you proceed? (Regarding effective permissions)

[1] https://www.microsoft.com/en-us/evalcenter/download-windows-server-2019

Exercise 2: RBAC

The new Standard for Access management is the Role Based Access Control Model. This model's implementation focuses heavily on "What can someone do to something", for instance, a user can write secrets on a Kubernetes ArgoCD namespace. This feature is implemented on several solutions and helps delegate responsibilities to be more refined and apply the least privilege security principle.

1. To test this approach the simple thing to use is to bring up a Kubernetes Cluster. Spin up a Minikube Instance[2].
2. Create three users[3].
3. Create at least three namespaces and their respective applications, you can use the examples from the Kubernetes repository.
4. Assign roles to each user to each namespace.
5. One User Can change deployments in any namespace, but it shouldn't be a cluster administrator.
6. Compare this model (RBAC) to the previously mentioned DACL model. How do they differ and what are the strengths and drawbacks of each one?

[2] https://minikube.sigs.k8s.io/docs/start
[3] https://kubernetes.io/docs/reference/access-authn-authz/rbac/